

# Analyzing the Unlinkability of SD-JWT

## A Machine Learning Perspective

Zahra Ebadi Ansaroudi · Alessandro Tomasi · Francesco Antonio  
Marino · Silvio Ranise

2nd International Workshop on Security and Risk in Identity Management (SeRIM 2026)

Lisbon, Portugal

2 July 10, 2026

# ROADMAP



*Context and SD-JWT background*

*Goal: Place SD-JWT in the wallet ecosystem and define what the Verifier observes.*



Privacy question and research goal



Methodology: Multiple-presentation unlinkability game + ML adversary  
Same User vs. different Users



Evaluation: Experiment ML adversary against configurations, datasets, and engineered features

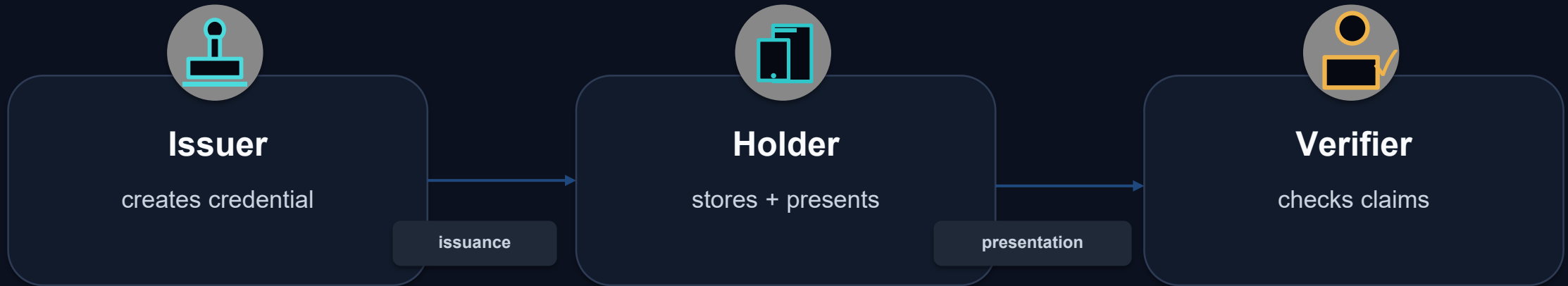


Synthesis & Feature importance and ablations

Goal: Identify which fields drive linkability and what this implies for deployments.

# Digital identity wallet ecosystem

Issuer, Holder, and Verifier in a selective-disclosure presentation



## What is sent? SD-JWT = Selective Disclosure JSON Web Token

An IETF draft mechanism for selectively disclosing individual claims from a signed JWT/JWS payload, used in identity credentials to reveal only the claims required by a Verifier.

# How SD-JWT Works

Mechanism

Selective disclosure is built from salted disclosures, signed digests, and verifier-side hash checks.



**SD-JWT:** Issuer-signed token containing digests of selectively disclosable claims.

**Disclosure:** Revealed claim package: [salt, claim name, claim value].

**KB-JWT:** Optional key-binding proof that ties the presentation to this verifier/session.

Presentation P= SD-JWT+Disclosures+KB-JWT

**Legend**

# Data Anatomy: From Issuance to Presentation

## Message Schematics for Credential (C) and Presentation (P)

### ISSUANCE MESSAGE (C)

$C := \text{IssuerSignedJWT} || \sim || \{\text{disc}_i\}$

```
// IssuerSignedJWT Payload
{
  "iss": "https://issuer.example.com",
  "iat": 1774831200, "exp": 1806367200,
  "sd_alg": "sha-256",
  "sd": [ "d_1", "d_2", "decoy_1" ], ← Digests
  "cnf": { "jwk": { "kty": "EC", ... } }
}

// Disclosure Objects (Detached)
disc_1: [salt, "given_name", "Alice"]
disc_2: [salt, "family_name", "Doe"]
```

### PRESENTATION MESSAGE (P)

$P := \text{IssuerSignedJWT} || \sim || \text{disc}_1 || \sim || \text{disc}_2 || \sim || \text{KB-JW}$

**Selected Disclosures**  
disc\_1, disc\_2

**Key Binding (KB-JWT)**  
Signed by Holder Key

```
// KB-JWT Payload
{
  "iat": 1774835800,
  "nonce": "gX9z2Kv7B1Wp",
  "sd_hash": "A3f9B7xW2..."
}
```

**Sd\_hash** is calculated over concatenated string segment:  
 $\text{IssuerSignedJWT} || \sim || \text{disc}_1 || \sim || \text{disc}_2$

# Selective disclosure is not the whole privacy story

Two related goals, but they answer different questions

## What is protected

Undisclosed claims are hidden behind salted digests.

## What remains visible

Verifiers may still observe disclosed attributes, credential metadata, repeated credential fields, and disclosure patterns.

## What remains risky

Observable signals may make presentations linkable.

Main research goal: **Can separate SD-JWT presentations still be recognized as coming from the same User?**

## Why machine learning (ML)?

Prior privacy work shows that ML can detect subtle patterns in observable data. We use it to test whether SD-JWT presentation pairs can be classified as **Linked** or **Not linked**.

# What does unlinkability mean?

Multiple presentations should not be linkable as coming from the same User.

## Different forms of unlinkability:

### **Presentation unlinkability**

A Verifier cannot link multiple presentations of the same credential by the same User.

### **Verifier/Verifier unlinkability**

Colluding Verifiers cannot determine that they received presentations from the same User.

### **Issuer/Verifier unlinkability, honest Verifier**

Issuer cannot learn when or where the User presents to an honest Verifier.

### **Issuer/Verifier unlinkability, colluding or compromised Verifier**

Issuer cannot determine presentation even with a colluding or compromised Verifier.

We focus on multiple-presentation unlinkability: **Presentation unlinkability + Verifier/Verifier unlinkability**

Multiple presentations associated with the same User should not be linkable by a single Verifier or by colluding Verifiers.

# Research questions

Two questions structure the evaluation

## RQ1: What signals matter?

Which verifier-observable signals most influence empirical linkability?

- Issuer-signed SD-JWT fields
- Revealed disclosures
- Optional KB-JWT fields

## RQ2: Do mitigations help?

To what extent do hygiene practices reduce linkability toward random guessing?

- Batch issuance
- Fresh keys and salts
- Randomized time claims

# Methodology: multiple-presentation unlinkability game

A challenge pair asks one question: do P0 and P1 come from the same User or different Users?

## 1. Setup

Generate Users and credentials.

Keep mapping:  
 $C_i \rightarrow U_j$ .

$I$  = disclosable claim indices.

Disclosure policy: DS1 or DS2.

## 2. Queries

A may query two oracles:

$\text{Present}(C_i, D)$   
returns  $P\{i, D\}$  with claims  $D$ .

$\text{Corrupt}(C_i)$   
reveals KB private key for  $C_i$ .

## 3. Challenge

Hidden bit  $b$ :

$b = 1$ : same User  
 $b = 0$ : different Users

Sample  $D_0, D_1$  subset of  $I$ .

Return fresh pair  $(P_0, P_1)$ .

## 4. Guess

A receives:  
 $(P_0, P_1)$

A outputs  $b'$

$b' = 1$ : Linked  
 $b' = 0$ : Not linked

### Freshness condition

$C_0$  and  $C_1$  are unseen and uncorrupted. After the challenge, A cannot query  $\text{Present}$  or  $\text{Corrupt}$  on them.

### DS1: default

$D_0$  and  $D_1$  may overlap. This models repeated disclosure of common attributes.

### DS2: experimental

$D_0$  and  $D_1$  are disjoint. This is not automatically more private; no-overlap can be observable.

Output: A wins if  $b' = b$ . Advantage =  $|\Pr[b = b'] - 0.5| \approx |\text{accuracy} - 0.5|$

# ML-based Unlinkability Analysis

We instantiate the PPT adversary  $A$  as a supervised binary classifier over verifier-observable presentation pairs.

## 1. Collect training data

Issue  $\text{Present}(C_i, D)$  queries.  
Sample each non-empty  $D$  subset of  $I$  uniformly at random.  
Sampling follows  $DS1$  or  $DS2$ .  
Build a number of presentations

## 2. Train classifier

Construct and train a classifier over labeled presentation pairs

**linked** = same User  
**not linked** = different Users

In batch issuance, use ground-truth  $C_i \rightarrow U_j$  mapping for labels.

## 3. Classify challenge

Receive fresh pair:  
 $(P_0, P_1)$   
Apply trained classifier.  
Output  $b'$  as the guess in the unlinkability game.

**The unlinkability game becomes a binary classification task: same User vs. different Users.**

Classifier accuracy estimates  $\Pr[b = b']$ ; advantage  $\approx | \text{accuracy} - 0.5 |$ .

# Experimental Setup

## 1. Configurations come first

### Conf1: baseline reuse

Single credential per User

1.1  $u=500, c=1, p=2 \rightarrow 1,000$  pairs

1.2  $u=1,500, c=1, p=2 \rightarrow 3,000$  pairs

**Purpose:** Expose whether repeated presentations of the same credential create strong structural linking signals in Verifier-visible fields.

### Conf2: batch issuance

Two credentials per user, each presented once.

2.1  $u=500, c=2, p=1 \rightarrow 1,000$  pairs

2.2  $u=1,500, c=2, p=1 \rightarrow 3,000$  pairs

**Purpose:** Test whether batch issuance with fresh KB keys, fresh salts, and randomized time claims reduces empirical linkability.

# Experimental Setup

**2. Dataset construction:** The construction starts from the SD-JWT-VC PID schema with 13 selectively disclosable User claims.

## 1 Generate credentials

Create PID credentials for  $u$  Users, up to  $m$  credentials per User. All 13 User claims are selectively disclosable.

## 2 Sample disclosures

Sample non-empty disclosure sets uniformly. DS1 allows overlap; DS2 samples disjoint paired disclosures.

## 3 Build pairs

Construct every unordered pair  $\{P_a, P_b\}$ ; label linked when both presentations originate from the same User.

## Why balance?

Pair construction scales quadratically, and not-linked pairs dominate. Random under-sampling creates a balanced linked/not-linked dataset for training and evaluation.

$$\text{Number of raw pairs} = \ell(\ell - 1) / 2$$

Notation:  $\ell$  = total presentations ( $u \times m \times p$ )

# Experimental Setup

## 3. Feature extraction follows pair construction

Manual feature selection keeps the ML adversary interpretable: It let us attribute linkability to interpretable verifier-observable sources, such as stable payload fields, disclosed content, disclosure similarity, Key Binding material, and repeated credential-derived components.

### 13 Pairwise Features

#### Equality Signals

payload\_sd

cnf.jwk

iat / exp

signature

disclosure salt

KB-JWT fields

#### Similarity Signals

Jaccard over disclosures

Cosine over disclosures

## 4. ML Classifiers

### Modeling Choices

**Conf1:** Linear Support Vector Machine

**Conf2:** L1-Regularized Logistic Regression

### Evaluation

10-fold Cross-Validation

# Evaluation: Metrics and feature importance

The classifier predicts whether each presentation pair is Linked or Not linked.

## Prediction outcomes

TP: linked pair predicted as linked

TN: not-linked pair predicted as not linked

FP: not-linked pair predicted as linked

FN: linked pair predicted as not linked

## Main evaluation metrics

Accuracy = overall fraction of correct predictions

$$= \frac{TP + TN}{TP + TN + FP + FN}$$

Precision = how reliable a Linked prediction is

$$= \frac{TP}{TP + FP}$$

Recall = how many truly linked pairs are detected

$$= \frac{TP}{TP + FN}$$

F1-score = balance between precision and recall

$$= \frac{2 \times P \times R}{P + R}$$

## Adversary advantage

Advantage approx | accuracy - 0.5 |

Measures how much better the adversary performs than random guessing.

## Feature importance

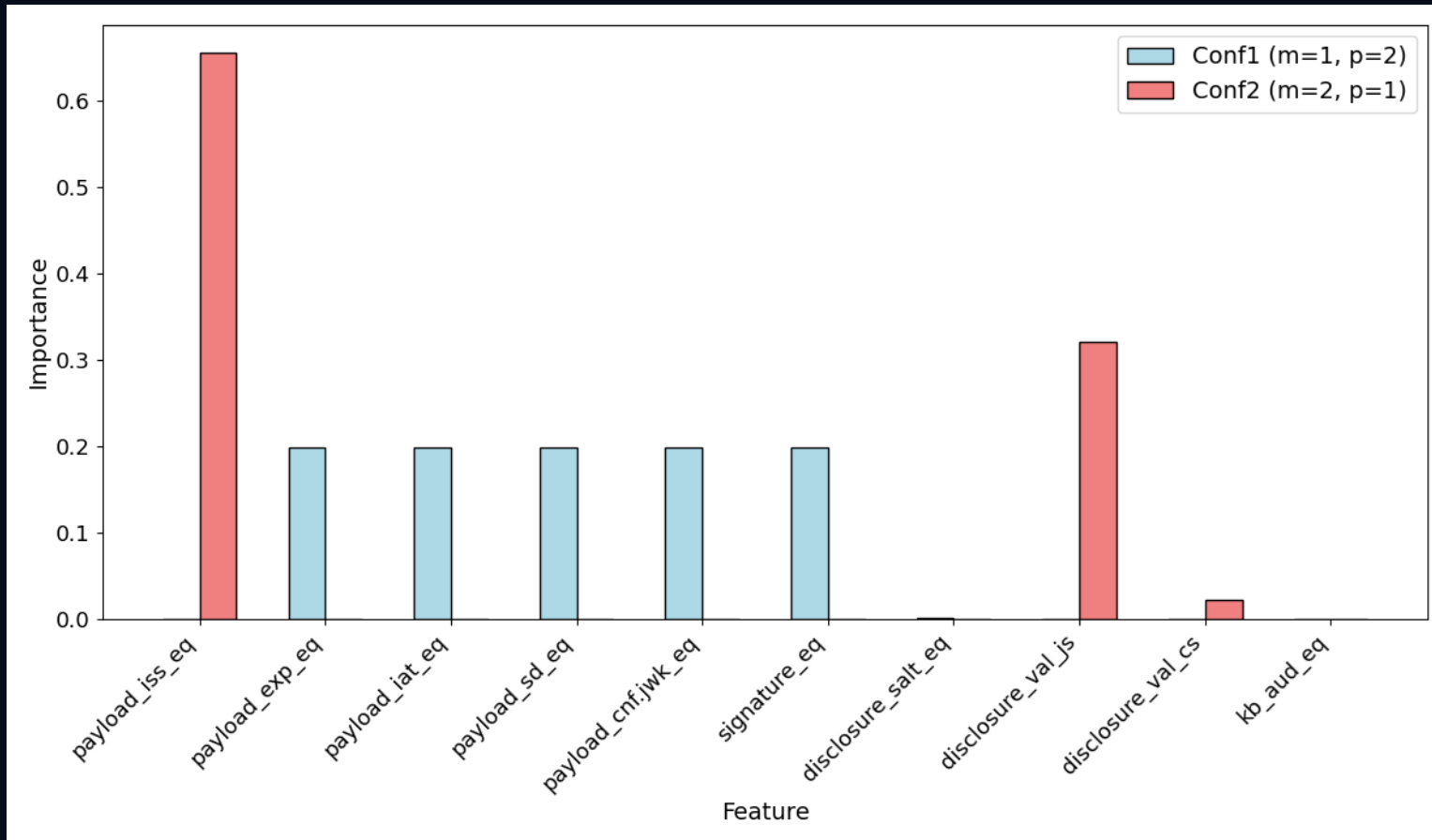
Shows which verifier-observable features contribute most to the classifier's decision.

We use it to interpret the source of linkability.

**High feature importance means the feature is useful for distinguishing same-User pairs from different-User pairs.**

# Results | RQ1: Conf1 is driven by stable presentation components

Feature importance for 500 Users shows different linking signals in Conf1 and Conf2.



## Conf1

Repeated presentations of the same credential expose strong equality signals: \_sd, cnf, iat, exp, and signature contribute equally to linkability.

## Conf2

When each credential is presented once, the model relies mainly on payload\_iss\_eq and disclosure-value similarity instead of repeated-presentation equality.

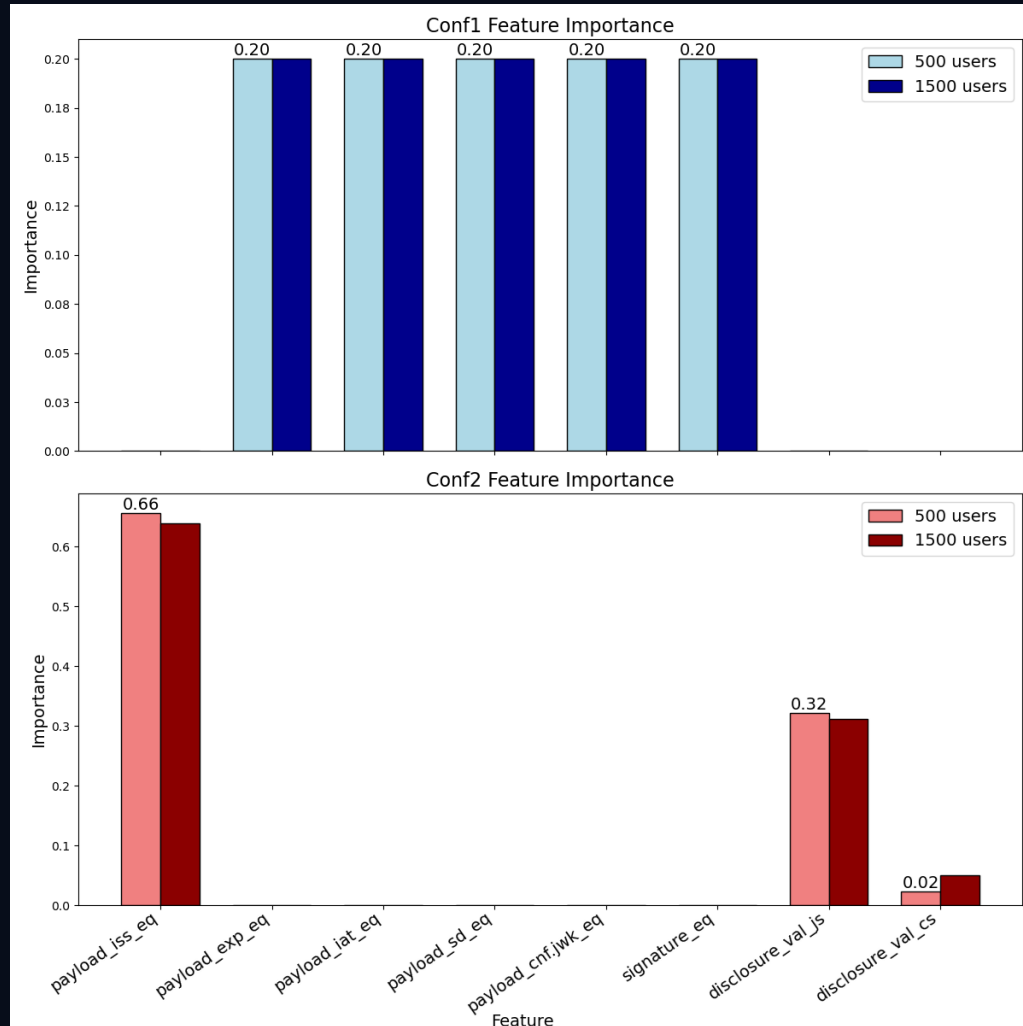
## Performance results, 500 Users

| Conf. | Precision | Recall | F1    | Accuracy |
|-------|-----------|--------|-------|----------|
| Conf1 | 1.000     | 1.000  | 1.000 | 1.000    |
| Conf2 | 0.793     | 0.950  | 0.864 | 0.849    |

Interpretation: Conf1 linkability is expected because repeated presentations preserve stable verifier-visible components.

# Results | RQ1: Feature importance is stable across user-base sizes

Increasing from 500 to 1500 Users does not materially change the dominant signals.



## Conf1 remains stable

The same equality features keep approximately equal importance for both 500 and 1500 Users.

## Conf2 shifts slightly

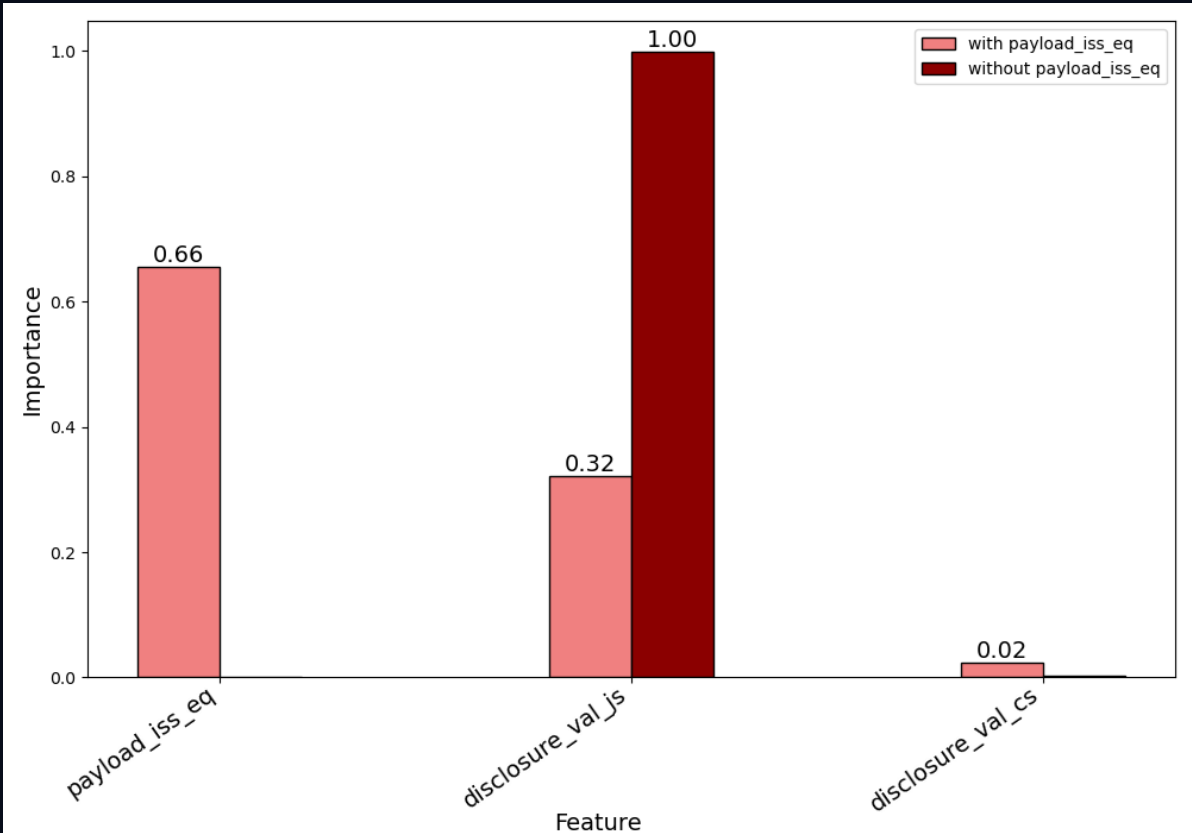
payload\_iss\_eq decreases slightly as the User population grows; disclosure similarity becomes relatively more visible.

## What this means

The model's behavior is not an artifact of a single dataset size; the same families of features explain linkability across evaluated scales.

# Results | Explaining residual linkability in Conf2

In Conf2, payload\_iss\_eq is a deployment-dependent linking signal rather than an SD-JWT selective-disclosure weakness.



Conf2 without payload\_iss\_eq

| Users | Precision | Recall | F1    | Accuracy |
|-------|-----------|--------|-------|----------|
| 500   | 0.693     | 0.560  | 0.616 | 0.654    |
| 1500  | 0.701     | 0.567  | 0.626 | 0.663    |

### Finding

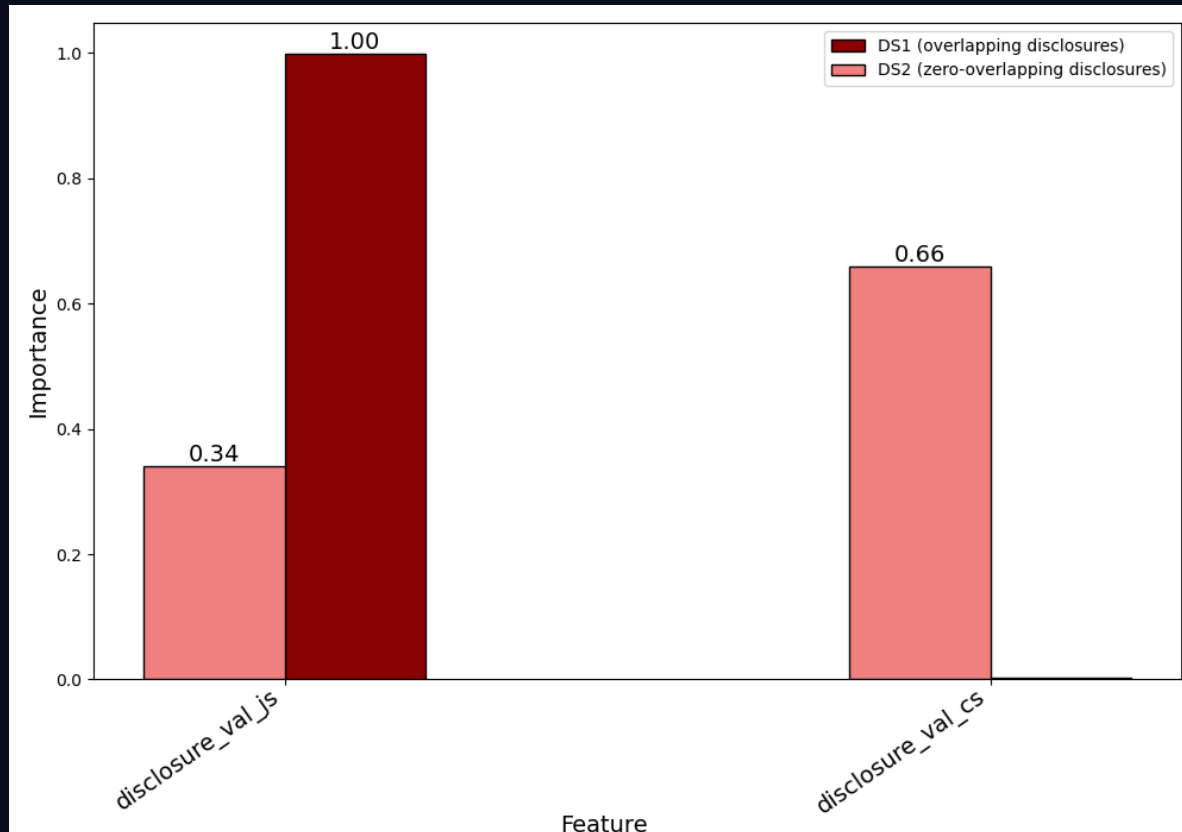
Removing the issuer equality feature causes a substantial performance drop, especially in recall. The remaining model shifts toward disclosure-value Jaccard similarity.

### Interpretation

Issuer identifiers can become linking metadata when credentials in a batch share the same Issuer identifier.

# Results | RQ2: Disclosure policy can itself become observable structure

Under DS2, the no-overlap pattern becomes a signal rather than a mitigation.



Conf2 under DS2 without payload\_iss\_eq

| Users | Precision | Recall | F1    | Accuracy |
|-------|-----------|--------|-------|----------|
| 500   | 0.667     | 0.794  | 0.724 | 0.696    |
| 1500  | 0.656     | 0.819  | 0.728 | 0.694    |

## Finding

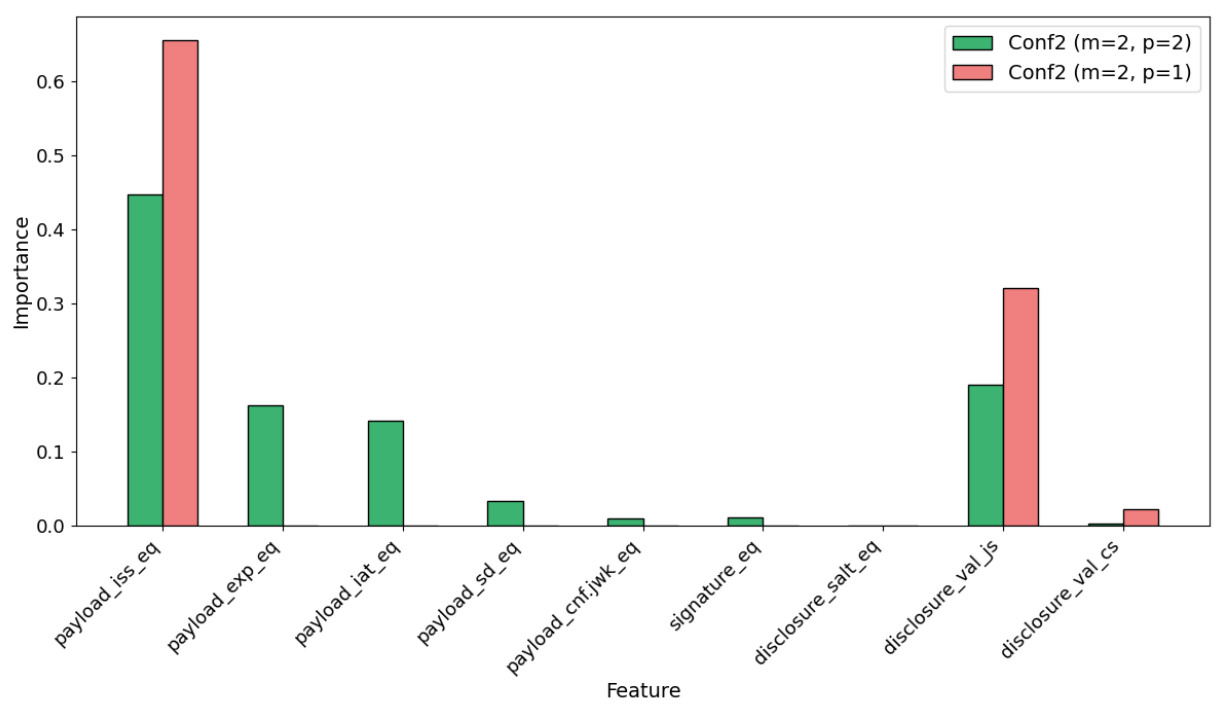
Accuracy increases relative to the issuer-removed DS1 setting, and Jaccard similarity becomes dominant.

## Interpretation

The result does not mean DS2 improves unlinkability. It shows that disclosure-overlap structure can be learned by the adversary.

# Results | RQ2: Credential reuse reintroduces stable linking cues

Presenting each credential twice changes the feature profile and preserves a non-trivial adversary advantage.



Conf2, m=2, p=2, full feature set

| Users | Precision | Recall | F1    | Accuracy |
|-------|-----------|--------|-------|----------|
| 500   | 0.842     | 0.886  | 0.863 | 0.859    |
| 1500  | 0.838     | 0.877  | 0.857 | 0.857    |

Reduced features: no issuer or disclosure similarity

| Users | Precision | Recall | F1    | Accuracy |
|-------|-----------|--------|-------|----------|
| 500   | 1.000     | 0.333  | 0.499 | 0.667    |
| 1500  | 1.000     | 0.333  | 0.500 | 0.667    |

## Interpretation

Even after removing issuer and disclosure-similarity signals, reuse leaves observable cues such as signatures and timestamps.

# Synthesis: Conf2 reduces linkability, but deployment choices matter

The remaining advantage is explained by what the Verifier can still observe.

## Answer to RQ1

In Conf1, repeated presentations of the same credential are dominated by stable equality signals. In Conf2, the dominant signals shift to issuer metadata and disclosed-claim similarity.

## Answer to RQ2

Linkability mitigations such as batch issuance reduces repeated-presentation equality signals, but does not automatically eliminate linkability if stable Issuer identifiers, disclosure patterns, or credential reuse remain visible.

Once disclosed claim content and stable Issuer identifiers are excluded, the evaluated default Conf2 setting drops to chance-level performance. This suggests no additional verifier-observable linking signal under our adversary model.

**Implication for deployment: unlinkability depends not only on SD-JWT selective disclosure, but also on deployment choices: number of issuers, disclosure policy, and limits on credential reuse.**

# Questions?

Thank you for your attention